Assessment 01: Security foundations

Individual assignment | Prepared from the supplied fictional scenarios

Name: Preet Kapoor	Batch/Group: AI Powered Cybersecurity

Task A | Secure a student account

A1-A2. Risks, assets, impact and controls

Risk	Asset at risk	CIA impact	Practical control	Limitation
Short password reused on email and portal	Email, course account and project files	Confidentiality: others may read data. Integrity: account content could be changed. Availability: account may be locked.	Use a long, unique password for each account, preferably stored in a password manager.	A strong password cannot stop phishing or malware that steals a login.
Approving unexpected MFA prompts	Email and learning portal access	Confidentiality and integrity may be lost if another person gets in.	Deny prompts you did not start. Report repeated prompts and use number matching or a passkey if available.	MFA is not foolproof; a user can still approve a prompt by mistake.
Postponing device updates	Laptop, saved work and accounts	Unpatched flaws can affect confidentiality, integrity and availability.	Install security updates promptly and enable automatic updates where practical.	Some updates need a restart, and updates cannot remove every possible risk.
Only project copy is on one laptop	Project files and coursework	Availability is at risk if the laptop fails or is lost. Integrity may be affected by corruption or ransomware.	Keep a separate backup and test that a file can be restored.	A backup that is always connected or never tested may also fail or be encrypted.
Friend uses laptop under Mira's signed-in account	Personal files and learning portal	Confidentiality: the friend can view data. Integrity: work or settings could be changed.	Lock the screen and create a separate account for the friend; sign out of the portal when finished.	A separate account helps only if it is actually used and protected.

Priorities - first three actions

1. Stop unexpected prompts and secure the email account. Do not approve a prompt just to make it stop. From a trusted device, change the reused password, review recovery details and sign out other sessions. Email comes first because it may be used to reset the other account.

2. Give each account a unique password and strengthen MFA. This limits damage if one service is breached. Use a phishing-resistant method if the portal supports one; otherwise, deny unrequested prompts and report them.

3. Patch the laptop and protect the work. Install pending updates, set an automatic screen lock, use a separate account for the friend and make a backup. These steps reduce device and data-loss risks, although backups still need testing.

A3. Authentication versus authorisation

Authentication checks that Mira is who she claims to be, for example by checking her password and an MFA factor. Authorisation decides what an authenticated user is allowed to do. After signing in, Mira may be allowed to view her own course material and submit assignments, but not to read another student's grades or change administrator settings. A successful login does not give someone permission to do everything in the portal.

Task B | Analyse a suspicious message

B1. Warning signs in the supplied message

Evidence phrase	Why it needs scrutiny
From: awards@campus-awards.example	The college normally uses campus.example. The sender domain is different, so it should not be trusted just because the display name says "Scholarship Desk".
Reply-To: help@personal-awards.example	The reply address uses another domain and does not match the stated college domain. It could route replies away from the college.
FINAL WARNING - scholarship expires in 20 minutes	The short deadline pressures the student to act before checking whether the message is real.
enter your college password and OTP	A password and one-time code are sensitive login secrets. Sharing them could let someone access the account.
Reply with a photo of your identity card	This asks for sensitive personal information that could be misused. The message gives no independently verified reason to send it by email.

B2. Safe verification process

1. Do not open the link or reply. Do not enter a password, OTP or ID details.

2. Open the college portal using a saved bookmark or an address obtained independently from official college material. Check for the scholarship notice after signing in normally.

3. Contact the scholarship or IT office using a phone number or email from the college's official directory, not the message. Ask whether the award and message are genuine, then report the message through the college's process.

HTTPS only protects the connection between a browser and a site; it does not prove that the site belongs to the college. A lookalike site can also use HTTPS. A familiar display name is easy to type or imitate, so the domain and sender must be checked independently.

B3. If the student already entered a password and OTP

1. Contact the official IT/security team immediately through a trusted contact method. Explain that both the password and OTP were entered, but do not send the secrets themselves.

2. From a trusted device, change the affected password through the official portal. Change it anywhere else it was reused, revoke active sessions if the service allows it, and reset or review MFA and recovery methods.

3. Check recent sign-ins, account recovery settings, forwarding rules and unfamiliar changes. If an identity-card photo was sent, tell the college office and follow its advice on protecting personal information. Keep the message for the security team and follow local reporting guidance if requested.

B4. What cannot be established from the message alone

The text alone cannot prove who actually sent the message or who controls the website. Helpful additional evidence would include the full email headers (including SPF/DKIM results), a check with the college through an independent channel and the college's own records of any scholarship announcement. The sample addresses are fictional training examples, so they should not be visited.

Task C | Triage a sign-in alert

C1. Four-point timeline: observations and interpretation

Time (IST)	Observed evidence	Interpretation - not yet proven
09:00-09:01	student07 had a successful password event and an approved MFA event from 192.0.2.10, the usual classroom egress IP.	This is consistent with ordinary access. The log does not independently confirm who used the account.
10:14-10:15	Two password failures came from 198.51.100.23, a different source IP.	Could be repeated guessing or a user mistyping a password. The different IP alone does not identify an attacker.
10:16-10:17	A password event succeeded from that IP; the following MFA event was denied.	Someone or something may have supplied the correct password, but this needs verification. The denied MFA step shows the sign-in was not yet fully approved.
10:18-10:20	MFA was approved and a session was created. student07 says they approved a prompt at about 10:18 to stop repeated requests and did not intend to sign in.	The approval may have allowed an unwanted sign-in. The session, device and factor details should be checked before drawing a firm conclusion.

C2. Likely explanation, alternative and checks

Likely explanation: Someone had or obtained the password and repeatedly triggered sign-in attempts. After the student approved an unexpected MFA prompt, a session was created. This pattern is consistent with an account takeover attempt using MFA prompt fatigue, but the logs do not prove how the password was obtained.

Alternative explanation: The activity may have come from the student using a different network, VPN or device, with the failed attempts caused by typing errors. This is less consistent with the student's statement, but it should still be checked rather than ruled out.

Two useful checks: (1) Review the identity provider's full sign-in record for device/browser details, MFA method, session or correlation IDs and any available location/network context. (2) Verify the activity with the student through a trusted channel and compare it with authorised device or VPN records. An IP address by itself does not prove a person's identity.

C3. Three prioritised actions for the authorised IT team

1. Preserve evidence first. Export the relevant authentication and MFA logs, session IDs, timestamps and available device details. Record who collected them and when; do not delete the suspicious logs.
2. Contain the account. Revoke active sessions and tokens, reset the password through a verified process, and review or re-register MFA methods after confirming the student's identity. Do not ask the student to share a password or OTP.
3. Check the scope. Review recent account changes and other sign-ins, including recovery settings and connected applications. Escalate according to the college incident process and document the outcome.

C4. Incident summary (60-100 words)

Between 10:14 and 10:16 IST, student07 had two failed password attempts and then a success from 198.51.100.23, unlike the usual classroom IP 192.0.2.10. MFA was denied at 10:17, approved at 10:18, and a session was created at 10:20. The student says they did not sign in and approved the prompt to stop the requests. This is consistent with possible password compromise and MFA prompt fatigue, but the IP does not identify an attacker. IT should preserve logs, revoke sessions, secure the account and verify device and session details.

Task D | Review an AI security answer

D1. Five unsafe or unsupported claims/actions and corrections

AI claim/action	Correction and reason
"The email is safe because it uses HTTPS."	HTTPS does not prove the sender or website is genuine. The message still has mismatched domains, urgency and requests for login secrets. Verify using the college portal or an independently obtained contact. [1]
"The logs prove that the person using 198.51.100.23 stole the password."	The logs show events from a source IP, not the identity of a person or how a password was obtained. The sequence is suspicious, but device, session and MFA details are needed before making a stronger claim.
"MFA prevents every account compromise."	MFA reduces risk but is not a guarantee. A student may approve a prompt by mistake, and some methods can be phished. Deny unexpected requests and use stronger, phishing-resistant MFA where available. [1]
"Delete the suspicious logs."	Do not delete them. Preserve the relevant records so the authorised IT team can reconstruct the sequence and investigate accurately. Record the collection time and protect the evidence from unauthorised changes.
"Send the student's password to support so they can test it."	Never send a password or OTP to support. IT should use approved account-recovery and verification processes. If compromise is suspected, reset credentials and revoke sessions rather than collecting the secret. [1]

D2. A safer prompt for an AI tool

> Analyse only the fictional email and synthetic sign-in log pasted below. Do not visit URLs, contact systems or assume an IP identifies a person. Separate direct observations from possible explanations. For every conclusion, state which supplied evidence supports it and what remains unknown. Identify the main risks and recommend safe, prioritised actions for an authorised college IT team. Do not request or repeat passwords, OTPs, identity documents or other secrets. Do not invent facts or citations; if evidence is insufficient, say so. Use the supplied CISA and NIST references where relevant, and clearly mark any recommendation that goes beyond the supplied evidence. Keep the answer concise and suitable for a student security assessment.

Why this prompt is safer

It limits the analysis to the supplied training evidence, asks for facts and assumptions to be separated, protects secrets, and requires uncertainty to be stated. This matters because generative AI can produce confident but incorrect statements or citations, so its output still needs checking against reliable evidence. [2]

Task D | Corrected advice and evidence notes

D3. Corrected security advice (100-150 words)

Do not trust this message just because it uses HTTPS or a familiar display name. The sender and reply-to domains differ from the college's normal domain, and the message pressures the student with a 20-minute deadline. It asks for a password, an OTP and an identity-card photo, then discourages contacting the college. These are strong warning signs, although the text alone does not prove who sent it. Do not open the link or reply. Check the scholarship through the official portal or a contact obtained independently. The logs show a password success, an MFA denial, an approval and a later session. Since the student says they approved the prompt without intending to sign in, treat the account as potentially compromised. IT should preserve the logs, revoke sessions, secure the account and review recent activity. Never share passwords or OTPs with support.

D4. AI-use declaration

AI tool used: ChatGPT. Purpose: to help organise and draft answers to the supplied fictional scenarios. The security conclusions were checked against the assignment evidence and the CISA and NIST references listed below. No live systems were tested and the fictional sample links were not visited. I will review and personalise the wording before submission.

Evidence/reference notes

1. Account and phishing guidance: CISA Secure Our World recommends strong unique passwords, multifactor authentication, software updates, and recognising and reporting phishing. This supports the controls and verification advice in Tasks A, B and D. [1]

2. Checking AI output: NIST AI 600-1 explains that generative AI can confidently present incorrect or inconsistent information (called confabulation in the report), including false supporting logic or citations. That is why the AI answer in Task D must be checked against the evidence rather than accepted automatically. [2]

References

[1] Cybersecurity and Infrastructure Security Agency (CISA), Secure Our World. https://www.cisa.gov/secure-our-world

[2] National Institute of Standards and Technology (NIST), Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1 (2024), section 2.2, "Confabulation". https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf